Seguridad, Calidad y Observabilidad

Este documento consolida la arquitectura de seguridad, calidad y observabilidad implementada en el sistema Bull Dog Solution conforme a `SPECS.md` y la Fase 12 del roadmap.

> **Alcance vigente:** describe controles del código, no una garantía de despliegue. AWS staging está eliminado y no existe producción desplegada. TLS, retención/backups de Drive y operación segura del ambiente deben verificarse al recrear un entorno; la IaC de staging expone HTTP en una IPv4 efímera y no crea TLS/ALB/CloudFront.

1. Seguridad de Red y Transporte

- **TLS / HTTPS:** Todas las comunicaciones externas deben realizarse exclusivamente bajo TLS 1.3/1.2.
- **CORS:** Configurado mediante lista blanca explícita de orígenes (`APP_ORIGIN`). Se rechazan orígenes no autorizados y se habilitan credenciales (`credentials: true`) únicamente para el origen frontend de la aplicación.
- **Cabeceras de Seguridad:** Uso de `helmet` con políticas de Content-Security-Policy, X-Content-Type-Options: nosniff, X-Frame-Options: DENY, y eliminación de cabecera `X-Powered-By` .

2. Autenticación y Gestión de Sesiones

- **Tokens Asimétricos:** Emisión de JWT de corta duración (15 minutos) firmados con par de claves asimétricas RSA/EdDSA.
- **Refresh Tokens Rotativos:** Los refresh tokens se almacenan en PostgreSQL con hash y revocación inmediata. Se transmiten mediante cookie HTTP-only con atributos `Secure` , `SameSite=Strict` y ruta restringida (`/api/v1/auth`).
- **Acceso técnico:** La política individual limita al técnico a órdenes de su asignación. Una cuenta TECHNICIAN designada para taller puede acceder solo a la única orden explícitamente habilitada; esa concesión no cambia el técnico asignado y se audita.

3. Protección de Datos y Almacenamiento

- **Inyección SQL:** No se utiliza SQL crudo no parametrizado. Todas las consultas se canalizan a través del ORM Prisma y PostgreSQL con parámetros vinculados.
- **Límites de Entrada:**
  - Payload JSON de Express acotado a 1 MiB.
  - Rate limiting central (`express-rate-limit`) con cuotas por IP y ventana de tiempo.
  - Validación de esquemas en todas las entradas mediante Valibot.

- **Archivos privados:**
  - Google Drive compartido es el proveedor seleccionado por la IaC de staging; S3/MinIO se conserva en el código para otros entornos.
  - En modo Drive, fotografías, firmas y PDFs se transfieren por rutas autenticadas de la API, que comprueba autorización y devuelve archivos privados sin cache. El adaptador de objetos utiliza URLs prefirmadas donde corresponde.
  - Verificación de metadatos (tipo MIME JPEG/PNG/WebP, tamaño máximo por imagen y dimensiones) antes de confirmar el registro.
- **Redacción de Secretos en Logs:**
  - Filtro central en Winston y Morgan que anonimiza y redacta automáticamente tokens de portador, contraseñas, cookies de refresh, claves de API, URLs firmadas y datos privados.

4. Observabilidad y Métricas

- **Endpoint Prometheus (`/metrics`):**
  - `http_requests_total` : Conteo de peticiones HTTP por método, ruta normalizada y código de estado.
  - `http_request_duration_seconds` : Latencia media por ruta.
  - `auth_login_failures_total` : Conteo de intentos de autenticación fallidos.
  - `uploads_failed_total` : Conteo de subidas fallidas.
  - `sheets_operations_total` : Operaciones hacia Google Sheets clasificadas por estado (`COMPLETED` , `FAILED` , `PENDING`).
  - `circuit_breaker_state` : Estado del interruptor de circuito (`CLOSED` , `OPEN` , `HALF_OPEN`).
  - `outbox_events_pending_total` y `outbox_oldest_event_age_seconds` : Monitorización de cola de sincronización.
  - `orders_by_status` : Conteo en tiempo real de órdenes por estado.
- **Health Checks:**
  - `/health/live` : Comprobación de proceso en ejecución sin dependencias.
  - `/health/ready` : Comprobación de conectividad a PostgreSQL y dependencias críticas.
  - `/health/metrics` : Instantánea JSON para supervisión administrativa.

5. Respaldo, Restauración y Limpieza de Almacenamiento

- **Respaldos de Base de Datos:** Script automatizado `infra/scripts/backup.sh` con compresión `gzip` , suma de verificación SHA256 y rotación de 30 días.
- **Restauración y Recuperación ante Desastres:** Script `infra/scripts/restore.sh` que valida la integridad del archivo y ejecuta la restauración en una sola transacción (`--single-transaction`).

- **Limpieza de Objetos Abandonados:** existe `infra/scripts/cleanup-orphaned-objects.ts` ; su alcance debe revisarse antes de usarlo (no asumir que cubre todas las referencias, en particular reportes Drive). No ejecutarlo para limpieza histórica sin autorización específica.